

Informe de intento de explotación mediante SQL Injection

Datos generales

Fecha: 10/06/2026

Aplicación evaluada: DVWA

Tipo de actividad: Prueba de seguridad en entorno de laboratorio

Introducción

En esta práctica se ha realizado una prueba básica de inyección SQL sobre DVWA , una aplicación diseñada para aprender sobre vulnerabilidades web de forma segura. El objetivo de la actividad es comprender cómo una entrada manipulada por un usuario puede afectar al funcionamiento de una consulta a la base de datos y observar las posibles consecuencias de este tipo de fallo.

Descripción del incidente

Durante la realización de pruebas sobre una aplicación web vulnerable, se llevó a cabo un intento de inyección SQL con el objetivo de comprobar si era posible alterar el comportamiento de las consultas realizadas a la base de datos.

La prueba consistió en introducir una cadena especialmente diseñada en uno de los campos de entrada de la aplicación. Dicha cadena pretendía modificar la condición lógica de la consulta ejecutada por el sistema.

Proceso de reproducción

Como parte de la prueba se utilizó la siguiente entrada:

```
1' OR '1'='1
```

Esta cadena se introdujo en el parámetro solicitado por la aplicación para evaluar cómo gestionaba los datos proporcionados por el usuario.

Tras enviar la petición, la aplicación respondió de una forma diferente a la esperada para una búsqueda normal. El comportamiento observado sugiere que la entrada proporcionada fue interpretada por la consulta SQL en lugar de tratarse únicamente como un dato de usuario.

La respuesta obtenida indica la posible existencia de una vulnerabilidad relacionada con la validación insuficiente de entradas.

Impacto del incidente

- Acceso no autorizado a información almacenada en la base de datos.
 - Obtención de registros distintos a los solicitados inicialmente.
 - Alteración del funcionamiento previsto de determinadas consultas.
 - Incremento del riesgo de exposición de información sensible.
-

Recomendaciones

Para evitar este tipo de vulnerabilidades, es recomendable validar correctamente los datos introducidos por los usuarios y utilizar consultas parametrizadas en lugar de construir las consultas directamente con la información recibida. Además, resulta conveniente realizar revisiones periódicas de seguridad para detectar posibles fallos antes de que puedan ser aprovechados.

Conclusiones

Los resultados observados durante la prueba sugieren que la aplicación podría ser susceptible a ataques de inyección SQL. Sería recomendable revisar los mecanismos de validación de entradas y el modo en que se construyen las consultas a la base de datos para reducir la exposición a este tipo de vulnerabilidades.

Como medidas preventivas, se recomienda el uso de consultas parametrizadas, validación estricta de entradas y la aplicación del principio de mínimo privilegio en las cuentas de acceso a la base de datos.

